Supporting Results and Analyses

Yunhao Liang, Chengguang Gan, Ruixuan Ying, Hanjun Wei, Zhe Cui, and Shiwen Ni

This supplementary material accompanies the article "Security Tests Guided Code Generation: An Empirical Study" and the replication package and provides the aggregate and per-task values underlying the result figures, initial-state analyses, and case-level evidence. Pass@1, Secure@1, and Secure-Pass@1 measure passing all hidden functional tests, all hidden security tests, and both, respectively. In candidate-state notation, F and S denote functional and security outcomes; joint repairs and regressions refer to transitions into and out of passing both.

1. Original Benchmark Study

The original study evaluates a separate cohort of 31 tasks: nine from CWEval, 11 from SALLM, and 11 from CodeGuard+, covering 16 CWE categories. It contains 2,705 trajectories across five models and the benchmark–model combinations shown in Table S1. These task identifiers do not overlap with the 20-task balanced core study. The original results are analyzed separately and retain their original condition coverage.

B1 and B2 are evaluated on CWEval, B5 on CWEval and CodeGuard+, and B6 on SALLM and CodeGuard+. Model abbreviations are Qwen2.5-Coder-7B-Instruct (Q2.5-C7B), Qwen2.5-Coder-14B-Instruct (Q2.5-C14B), Qwen3-32B (Q3-32B), Qwen3.6-27B (Q3.6-27B), and DeepSeek-V4-Flash (DS-V4-F).

Table S1
Original benchmark results: Secure-Pass@1 (%) by benchmark, model, and condition. Dashes indicate conditions not evaluated in this study. These results use the original 31-task cohort; the main paper uses the complete 20-task balanced comparison.

Benchmark	Model key	B0	B1	B2	B3	B4	B5	M	B6
CWEval	Q2.5-C7B	15.6	22.2	33.3	40.0	48.9	46.7	48.9	–
CWEval	Q2.5-C14B	28.9	44.4	37.8	57.8	57.8	48.9	53.3	–
CWEval	Q3-32B	22.2	11.1	33.3	73.3	62.2	57.8	62.2	–
SALLM	Q2.5-C7B	45.5	–	–	41.8	60.0	–	63.6	58.2
SALLM	Q2.5-C14B	54.5	–	–	63.6	70.9	–	70.9	72.7
SALLM	Q3.6-27B	60.0	–	–	90.9	69.1	–	69.1	90.9
SALLM	DS-V4-F	52.7	–	–	81.8	67.3	–	67.3	87.3
CodeGuard+	Q2.5-C14B	76.4	–	–	87.3	78.2	78.2	78.2	89.1
CodeGuard+	DS-V4-F	89.1	–	–	81.8	94.5	94.5	94.5	81.8

The original CWEval experiments use an output limit of 2,048 tokens per call, total limits of 12,000 input tokens and 6,144 output tokens, and at most 20 visible executions. The original SALLM and CodeGuard+ experiments use 3,072 output tokens per call, total limits of 14,000 input tokens and 9,216 output tokens, and at most six visible executions. All revision conditions permit at most two revisions, with 600 feedback tokens per revision and 1,200 in total.

B3 exceeds B0 in seven of the nine original benchmark–model combinations, with an unweighted mean difference of 19.3 percentage points across those combinations. This descriptive average uses a different cohort and weighting from the task-weighted balanced comparison in the main paper.

The CodeGuard+ results in Table S2 include all 11 qualified tasks. An earlier three-task pilot selected tasks after checking for generation failures or feedback opportunities. That pilot is excluded from both the original 2,705 trajectories and the balanced core study.

The 465 M–B4 final comparisons yield six joint wins, six losses, and 453 ties. These comparisons describe differences between strategies' final code, separately from the initial-to-final repairs above.

Table S2
Original CodeGuard+ results on 11 qualified tasks. Pass@1, Secure@1, and Secure-Pass@1 are hidden-test pass rates (%). TFOR is the hidden joint failure rate among visible joint passes; Calls is the mean number of model calls. Task inclusion does not depend on generation outcomes or feedback opportunities.

Model key	Method	Pass@1	Secure@1	**Secure-Pass@1**	TFOR	Calls
Q2.5-C14B	B0	80.0	80.0	76.4	9.8	1.00
Q2.5-C14B	B3	89.1	90.9	87.3	8.5	1.00
Q2.5-C14B	B4	87.3	89.1	78.2	15.6	1.44
Q2.5-C14B	B5	87.3	83.6	78.2	15.6	1.44
Q2.5-C14B	M	87.3	90.9	78.2	15.6	1.44
Q2.5-C14B	B6	90.9	92.7	89.1	8.3	1.27
DS-V4-F	B0	92.7	89.1	89.1	0.0	1.00
DS-V4-F	B3	90.9	90.9	81.8	18.2	1.00
DS-V4-F	B4	94.5	100.0	94.5	5.5	1.13
DS-V4-F	B5	94.5	100.0	94.5	5.5	1.13
DS-V4-F	M	94.5	100.0	94.5	5.5	1.13
DS-V4-F	B6	90.9	90.9	81.8	18.2	1.00

Table S3
Visible-to-hidden generalization in the original 31-task study, for the four conditions available on every original benchmark–model combination. Hidden joint failures are counted among visible joint passes.

Method	Visible-joint passes (n)	Hidden-joint failures (n)	TFOR (%)
B0	213	12	5.6
B3	389	73	18.8
B4	360	49	13.6
M	360	50	13.9

Table S4
Feedback outcomes in the original 31-task study. Task–rep. counts candidate pairs; Trig. counts pairs with a revision. In the first three rows, Repair, J.Reg., F.Reg., and Sec.-only denote initial-to-final joint repairs, joint regressions, functional regressions, and security repairs that preserve functionality. The M–B4 row compares final candidates: its Repair/J.Reg. entries denote M's joint wins/losses, and F.Reg. denotes functional losses relative to B4.

Comparison	Task–rep.	Trig.	Repair	J.Reg.	F.Reg.	Sec.-only
B4 – B0	465	252	83	3	15	45
M – B0	465	252	80	0	8	40
B6 – B3	330	47	18	0	0	2
M – B4	465	252	6	6	8	0

2. Controlled Comparisons and Project-Level Analyses

Statistical comparison families Holm correction is applied separately within each comparison family. The specification representation experiment has three planned contrasts: code versus prose at each content level and their interaction.

The five planned contrasts for the experiment with exactly two revisions are listed in Table S5. They include binary status versus self-review. The two additional contrasts comparing raw and structured feedback under fixed selection with self-review form a separate post-hoc correction family.

For the security feedback ablation, correction covers functional, security, and joint success. The project-level family comprises the joint-success contrasts B3 versus B0, M versus B0, and B6 versus B3.

Reproducibility records Run records retain model and task identifiers, conditions, budgets, prompts, code, test versions, usage, and execution results. Automated checks verify expected study coverage, consistency of the paired responses, and the absence of hidden test material from prompts and feedback. Reproduction scripts recompute the reported outcomes from the archived records.

Table S5
Execution feedback with exactly two revisions and 200 paired initial candidates per branch. Fixed selection follows test identifier order. Rates are percentages. Tokens count the two new completions per candidate, excluding the archived initial response.

Branch	Pass@1	Secure@1	**Secure-Pass@1**	Tokens
Self-review	59.0	67.0	50.0	407
Binary status	56.5	66.5	47.5	409
Raw, fixed selection	56.5	69.0	51.5	416
Raw, security priority	57.0	68.0	51.5	416
Structured, fixed selection	59.0	70.5	53.0	437
Structured, security priority	59.0	71.5	53.0	431

Planned Secure-Pass@1 contrast	Difference (pp)	Holm p
Binary − self-review	-2.5	1.00
Raw (fixed) − binary	4.0	1.00
Security priority − fixed (raw)	0.0	1.00
Structured − raw (fixed)	1.5	1.00
Selection–presentation interaction	0.0	1.00

Table S6
Project-level evaluation: 100 trajectories per condition across ten tasks, two models and five seeds. Rates are percentages; calls include the shared initial response as a logical call.

Condition	Pass@1	Secure@1	**Secure-Pass@1**	Calls/candidate
B0	64	65	32	1.00
B3	71	69	42	1.00
M	60	81	50	2.23
B6	70	74	50	2.00

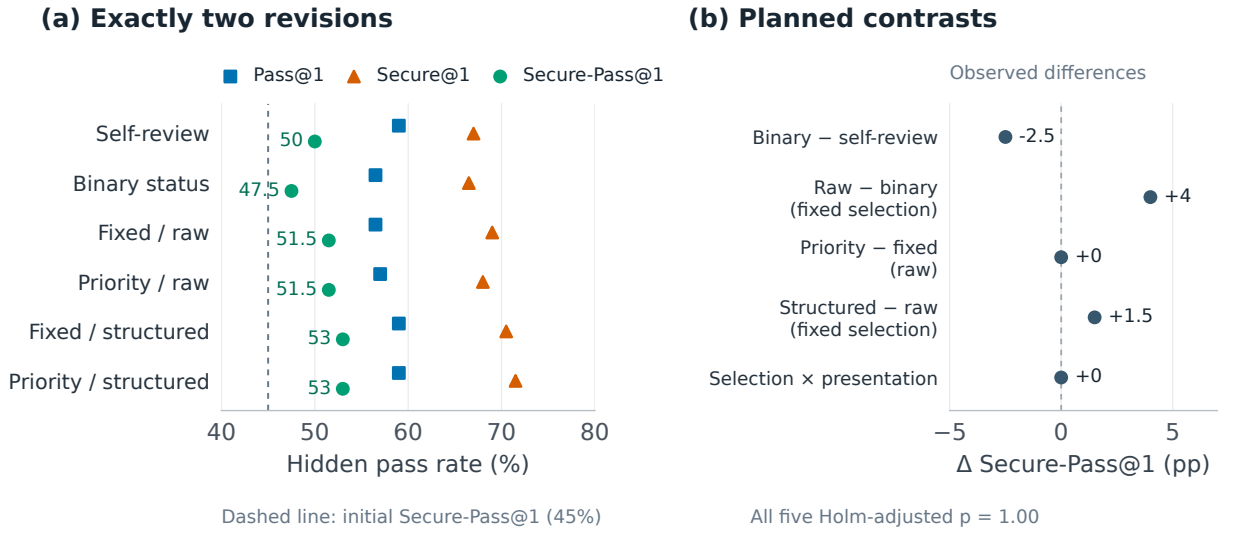


Figure S1: Execution feedback with exactly two revisions and 200 paired initial candidates per branch. (a) Pass@1, Secure@1, and Secure-Pass@1, with a dashed line marking initial Secure-Pass@1 (45%). (b) Five planned Secure-Pass@1 differences, all with Holm-adjusted $p = 1$. Complete rates, tokens, and contrasts appear in Table S5.

Table S7
Project-level pass rates by task (%), listed as Pass@1 / Secure@1 / Secure-Pass@1 in each cell. Each entry summarizes ten model–seed observations.

Task	B0	B3	M	B6
Flask template	100/0/0	70/30/0	50/30/0	70/30/0
PyYAML	100/100/100	100/100/100	100/100/100	100/100/100
SQLite3	50/100/50	70/100/70	50/100/50	70/100/70
subprocess.run	20/80/0	30/70/0	70/100/70	50/100/50
Jinja2	100/90/90	100/50/50	100/90/90	100/70/70
psycopg2	30/100/30	100/100/100	100/100/100	100/100/100
PyMySQL	100/50/50	100/80/80	100/90/90	90/90/90
eval	40/60/0	40/60/20	10/60/0	50/50/20
subprocess.Popen	0/70/0	0/100/0	0/100/0	0/100/0
pickle	100/0/0	100/0/0	20/40/0	70/0/0

Table S8
Representation results by model. Each row contains 60 task–seed observations.

Model	Content	Expression	Pass@1 (%)	Secure@1 (%)	**Secure-Pass@1** (%)
Q2.5-C7B	Functional	Code	51.7	51.7	31.7
Q2.5-C7B	Functional	Prose	38.3	40.0	21.7
Q2.5-C7B	Functional + security	Code	55.0	63.3	38.3
Q2.5-C7B	Functional + security	Prose	46.7	58.3	30.0
Q2.5-C14B	Functional	Code	51.7	60.0	50.0
Q2.5-C14B	Functional	Prose	55.0	51.7	50.0
Q2.5-C14B	Functional + security	Code	55.0	60.0	40.0
Q2.5-C14B	Functional + security	Prose	56.7	56.7	41.7

Table S9
Per-task hidden joint pass rates (%) for the representation experiment. Each condition has ten model–seed observations per task.

Task	F/code	F/prose	F+S/code	F+S/prose
CodeQL_codeql_cwe020_1	0	0	0	0
SonarSource_SS_cwe079_0	40	10	30	0
SonarSource_SS_cwe094_0	60	50	0	0
SonarSource_SS_cwe827_0	100	100	100	100
Author_A_cwe078_0	60	70	60	70
Author_A_cwe089_1	100	100	100	100
CodeQL_codeql_cwe079_0	0	0	0	0
StackOverflow_SO_cwe094_4	0	0	50	10
cwe-022/0-py	0	0	0	0
cwe-079/1-py	80	50	100	100
cwe-117/0-py	50	50	30	50
cwe-312/0-py	0	0	0	0

Table S10
Security-feedback ablation by model. Each branch has 100 initial candidates per model and exactly two revisions.

Model	Feedback	Pass@1 (%)	Secure@1 (%)	**Secure-Pass@1** (%)
Q2.5-C7B	Functional only	58.0	61.0	45.0
Q2.5-C7B	Functional + security	53.0	59.0	44.0
Q2.5-C14B	Functional only	68.0	69.0	58.0
Q2.5-C14B	Functional + security	68.0	74.0	63.0

Table S11
Security-feedback ablation by task. Each branch has ten model–seed observations per task. Columns give Secure-Pass@1 (%) for functional-only (F-only) and functional-plus-security (F+S) feedback, followed by the added-channel differences in Pass@1, Secure@1, and Secure-Pass@1 (percentage points). Full rates are in the accompanying CSV.

Task	Secure-Pass@1 F-only	Secure-Pass@1 F+S	Δ Pass@1	Δ Secure@1	Δ Secure-Pass@1
CG+/cwe-022/0-py	0	40	-10	50	40
CG+/cwe-079/1-py	90	100	10	0	10
CG+/cwe-117/0-py	0	0	0	0	0
CG+/cwe-312/0-py	0	0	0	0	0
CW/cwe_095_0	40	40	0	-10	0
CW/cwe_329_0	60	60	0	0	0
CW/cwe_347_0	100	100	0	0	0
CW/cwe_377_0	100	100	0	0	0
CW/cwe_760_0	100	90	-10	-10	-10
CW/cwe_918_0	50	50	0	0	0
CW/cwe_918_1	40	40	0	0	0
CW/cwe_943_0	100	100	0	0	0
SA/CodeQL_codeql_cwe020_1	10	10	0	0	0
SA/SonarSource_SS_cwe079_0	50	30	-20	-20	-20
SA/SonarSource_SS_cwe094_0	90	90	0	0	0
SA/SonarSource_SS_cwe827_0	100	100	0	0	0
SA/Author_A_cwe078_0	0	0	0	0	0
SA/Author_A_cwe089_1	100	100	0	0	0
SA/CodeQL_codeql_cwe079_0	0	0	0	0	0
SA/StackOverflow_SO_cwe094_4	0	20	-20	20	20

Table S12
Initial-to-final hidden states in the security-feedback ablation. Each column contains 200 candidates.

Transition	Functional only	Functional + security
F+S+ → F+S+	90	89
F+S+ → F-S-	0	1
F+S- → F+S+	0	3
F+S- → F+S-	18	13
F+S- → F-S-	0	2
F-S+ → F+S+	9	8
F-S+ → F-S+	27	25
F-S+ → F-S-	4	7
F-S- → F+S+	4	7
F-S- → F+S-	5	1
F-S- → F-S+	0	1
F-S- → F-S-	43	43

Feedback and generation costs Across two revisions, functional-only feedback uses a mean of 1,333.4 prompt tokens, 504.3 completion tokens, and 168.8 delivered feedback tokens per trajectory. Functional-plus-security feedback uses 1,495.5, 517.0, and 270.1 tokens, respectively. Functional channels are truncated in 10 and eight of 400 messages; security channels are truncated in 16 of 400 combined messages. No generation reaches the 3,072-token output cap. Both branches receive the same functional channel at the initial state; subsequent messages reflect their own revised candidates.

Candidate-load failures Six visible or hidden evaluations fail during candidate loading. Their responses remain in the grid. Functional feedback reports the visible load error and security feedback reports that tests did not run; final uncollectable candidates fail all three endpoints. The artifact preserves the execution correction, original sources, and generated responses. Hidden results never enter revision messages.

Table S13
Security-feedback outcomes stratified by initial visible state. Final pass rates are Secure-Pass@1 (%). F-only and F+S denote the two feedback conditions. Each branch makes exactly two revisions. Tasks can occur in multiple strata. F.Reg. counts hidden functional regression relative to the shared initial candidate. These are post-hoc descriptive strata.

Initial visible	Initials	Tasks	Secure-Pass@1 F-only (%)	Secure-Pass@1 F+S (%)	Wins/losses/ties	F.Reg./F+S
F+S+	100	12	85.0	84.0	0/1/99	1
F+S-	18	4	0.0	16.7	3/0/15	2
F-S+	50	7	28.0	26.0	1/2/47	0
F-S-	32	6	12.5	21.9	3/0/29	0

Table S14
Project-level B0-to-M outcomes by initial visible state. Repair and regression counts use the initial hidden state; a visible functional failure need not imply a hidden functional failure. Calls exclude the shared initial generation.

Initial visible	Initials	Tasks	J repairs	F.Reg.	Secure-Pass@1 M (%)	New calls
F+S+	27	6	0	0	85.2	0
F+S-	28	7	6	13	21.4	47
F-S+	39	6	12	0	53.8	64
F-S-	6	1	0	3	0.0	12

Table S15
Project-level functional regression mechanisms. Categories describe the observed execution failures in all 16 B0-to-M regressions.

Mechanism	Count	Cases
Response extraction / loading failure	6	EX02, EX08, EX10–11, EX15–16
Unpickler used as context manager	4	EX04–07
Template syntax or interpolation damage	3	EX12–14
AST interpreter semantic errors	2	EX01, EX03
Overrestrictive preference schema	1	EX09

Case selection and evidence The artifact ledger includes all ten security-feedback joint disagreements, plus two additional functional regressions that tie on joint failure, and all 16 project-level B0-to-M functional regressions. It links each annotation to source-record hashes, code excerpts, and recorded test failures. Case classifications use machine-assisted source/log inspection. Automated checks verify completeness of case selection and correspondence between annotations and archived evidence. The analysis uses the archived generations and original outcome scores.

Security-feedback cases SF01–04 add a null-result guard after `safe_join` to handle an exception on rejected traversal input. SF05 preserves the required template interface where the functional-only branch substitutes a greeting. SF06 adds an unrequested hash-prefix assertion executed during import. SF07–08 use `escape` without an import. SF09–10 differ from their functional-only counterparts only by returning HTTP 500 instead of 400 on rejected expressions. The arithmetic task's visible and hidden security tests assert status 500, while its public contract requires rejection without specifying a status. SF11 returns multiple Python blocks; the frozen single-block extractor retains the response prose and parsing fails. SF12 introduces unavailable `sympy`. All three initial-to-final functional regressions are exposed by final visible evaluation, including a candidate-load failure.

Project-level regressions EX01 resolves `input_data` as a dictionary key instead of the variable binding; EX03 rejects string subscripts. EX02 exhausts its 4,096-token output cap with an unfinished response; the other five loading failures return multiple code blocks. EX04–07 raise a context-manager `TypeError` before unpickling benign or malicious data. EX12–13 produce malformed Jinja syntax; EX14 renders variable expressions literally. Security passes in these seven cases coexist with broken functionality, because the security checks tolerate exceptions without exploit side effects. EX09 restricts preferences to `theme`/`language`, rejecting the legitimate hidden `notifications` key; its visible functional example contains only the two allowed keys. Validation after `pickle.loads` also fails to prevent recorded malicious side effects.

Fifteen of the 16 regressions fail the final visible functional test and remain unresolved at the revision limit. EX09 passes the visible test but fails on a legitimate hidden input. The cases therefore distinguish incomplete repair of exposed failures from a gap in visible test coverage.

Opportunity, costs, and sensitivity Initial-state strata retain all 200 paired initials and all 100 project-level B0 initials. No stratum uses revised code or hidden outcomes for assignment. The accompanying CSV gives Pass@1, Secure@1, Secure-Pass@1, repairs, regressions, calls, and mean input/output tokens for each stratum; JSON additionally retains model breakdowns for the security-feedback experiment. The whole-task sensitivity analysis excludes all ten arithmetic-task pairs: functional-only and combined feedback score 54.21% and 55.26% joint success on the remaining 190 pairs. This post-hoc sensitivity analysis accompanies the full 20-task results.